

NAME	KEN KIBUGI MUIRURI
TRACKING NUMBER	CS-SA12-26014
COHORT	CYBERSHUJAA COHORT 1-2026
TASK	VULNERABILITY ASSESSMENT REPORT

Contents

1.0 Security Assessments	3
1.1 Security Assessments	3
1.2 Vulnerability Assessment.....	3
1.3 Assessment Standards	3
2.0 Vulnerability Scoring and Reporting.....	4
2.1 Common Vulnerability Scoring System (CVSS).....	4
2.2 Common Vulnerabilities and Exposures (CVE)	4
3.0 Nessus	4
3.1 Vulnerability Scanning Overview	4
3.2 Nessus Scan	4
3.3 Advanced Settings	4
3.4 Working with Nessus Scan Output	5
3.5 Scanning Issues	5
3.6 Nessus Skills Assessment	5
4.0 OpenVAS.....	9
4.1 OpenVAS Scan	9
4.2 Exporting The Results.....	9
4.3 OpenVAS Skills Assessment	9
5.0 Reporting	11
5.1 Reporting	11
Conclusion	12

VULNERABILITY ASSESSMENT REPORT

Introduction

In this report, I learned how vulnerability assessments are planned, executed, and reported using industry-standard tools and methodologies. The focus was on understanding how automated vulnerability scanning works, how tools like Nessus and OpenVAS are configured, and how their results are interpreted and validated. This module emphasized the importance of standards, proper scoping, and careful analysis to identify real security risks while minimizing impact on target systems.

Here is a shareable link to my completed module:

<https://academy.hackthebox.com/achievement/2380391/108>

1.0 Security Assessments

1.1 Security Assessments

I learned that security assessments are used to identify and manage vulnerabilities in systems, networks, and applications based on an organization's risk tolerance and security maturity. Vulnerability assessments focus on identifying known issues against standards, while penetration tests simulate real attacks to evaluate impact, with other approaches like audits, bug bounties, red, and purple team assessments supporting a well-rounded security strategy.

1.2 Vulnerability Assessment

I learned that a vulnerability assessment focuses on identifying and categorizing security weaknesses in an environment with little to no exploitation, while providing clear remediation guidance. It relies on asset inventory, risk evaluation (based on likelihood and impact), and standardized scoring like CVSS to help organizations prioritize and manage vulnerabilities effectively.

1.3 Assessment Standards

I learned that vulnerability assessments and penetration tests must follow recognized standards to ensure legality, consistency, and acceptance by regulatory bodies. Compliance frameworks like PCI DSS, HIPAA, FISMA, and ISO 27001 guide vulnerability management, while pentesting standards such as PTES, OSSTMM, NIST, and OWASP define structured and ethical testing approaches.

2.0 Vulnerability Scoring and Reporting

2.1 Common Vulnerability Scoring System (CVSS)

I learned that CVSS is a standard way to measure the severity of vulnerabilities, helping me prioritize which issues to address first. It considers exploitability, impact on confidentiality, integrity, and availability, and factors like exploit maturity and remediation level.

2.2 Common Vulnerabilities and Exposures (CVE)

I explored how OVAL and CVE help standardize vulnerability management and reporting. OVAL provides a language to describe system states, configurations, and patches, allowing me to identify issues without exploiting them directly.

CVE assigns unique identifiers to publicly known vulnerabilities, making it easier to track, assess, and remediate security issues. Following responsible disclosure practices, I understand how vulnerabilities are reported to vendors before being publicly announced to prevent misuse.

3.0 Nessus

3.1 Vulnerability Scanning Overview

I learned that vulnerability scanning is an automated way of identifying known or potential weaknesses across network devices, systems, and applications without actively exploiting them. Scans can be static (version/CVE-based) or dynamic (testing benign payloads), but results still need human validation to separate real issues from false positives.

3.2 Nessus Scan

I learned how to configure a Nessus scan by selecting appropriate templates like the Basic Network Scan and defining specific targets.

3.3 Advanced Settings

I explored Nessus advanced settings by creating custom scan policies, managing plugins, and configuring credentialed scans for deeper visibility. I learned how plugin rules help reduce false positives while keeping detections active where they matter.

3.4 Working with Nessus Scan Output

I learned how to analyze and export Nessus scan results in formats like PDF, HTML, CSV, and raw .nessus files for further processing. I saw how executive summaries help communicate risk clearly, while CSV and raw exports are better for analysis, automation, or integration with other tools.

3.5 Scanning Issues

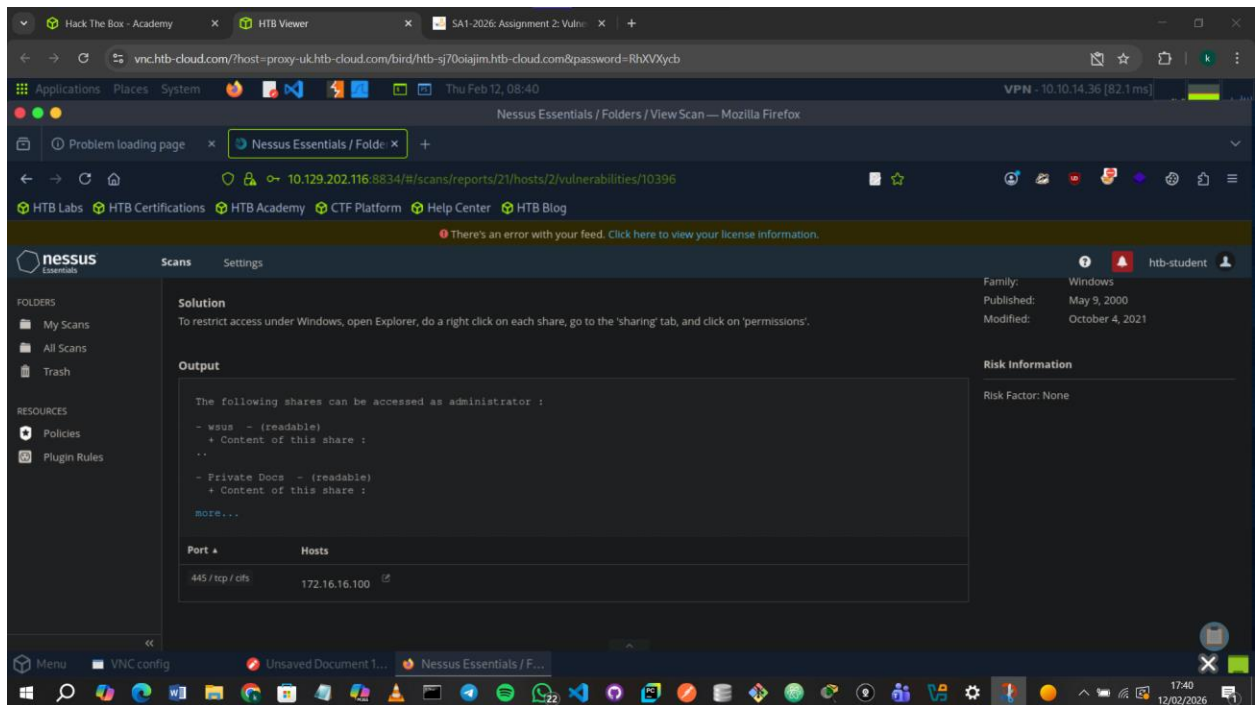
I learned that vulnerability scans can negatively impact networks or produce false results if not carefully planned. I saw how tuning scan settings, enabling safe checks, rate-limiting, and excluding sensitive systems can reduce risk and noise. This reinforced the importance of clear communication with stakeholders and understanding network impact before and after scanning.

3.6 Nessus Skills Assessment

I started by logging in to the given address at port 8800 using the provided credentials.

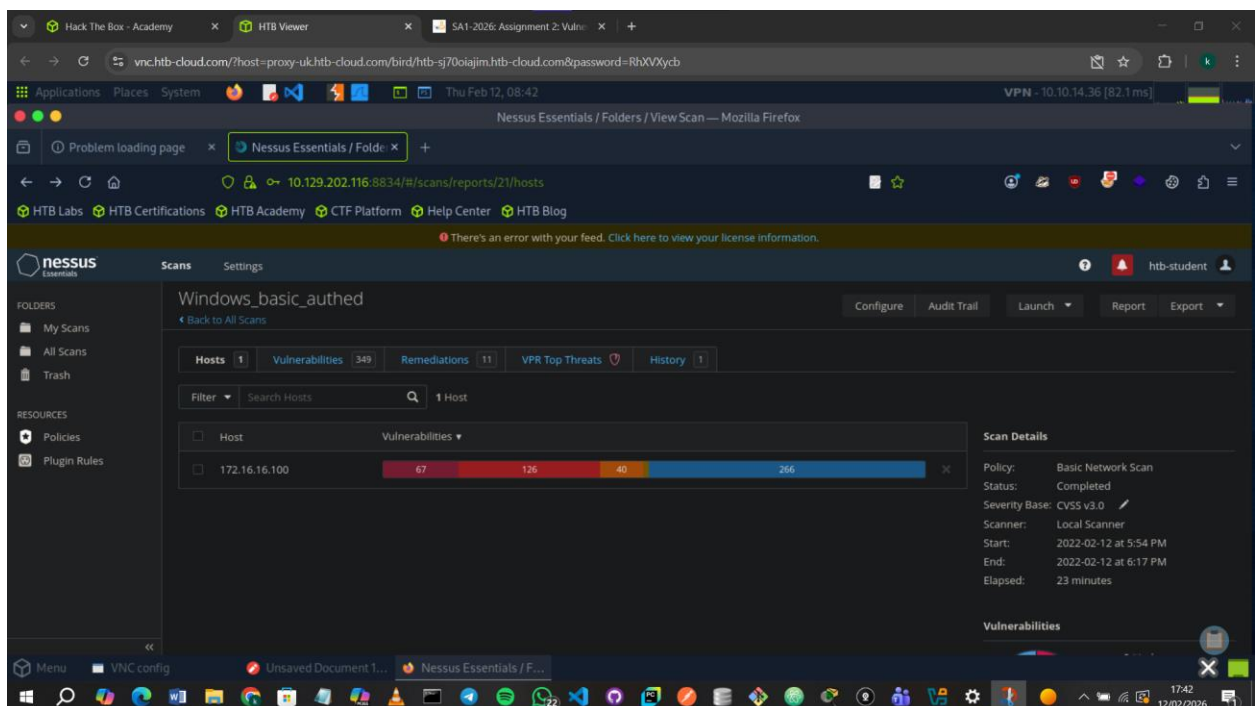
Question1: What is the name of one of the accessible SMB shares from the authenticated Windows scan?

Answer: I filtered the scan results using SMB and opened Microsoft Windows SMB shares Access and found the name as **wsus**.



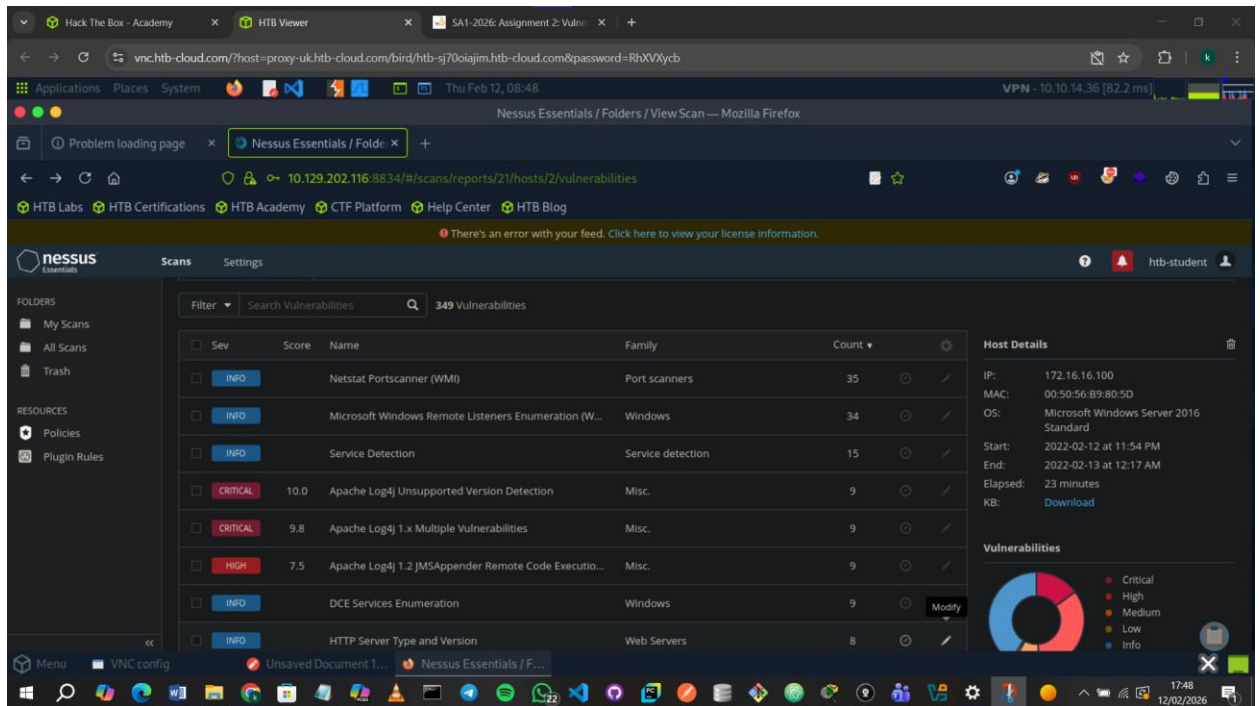
Question2: What was the target for the authenticated scan?

Answer: **172.16.16.100**

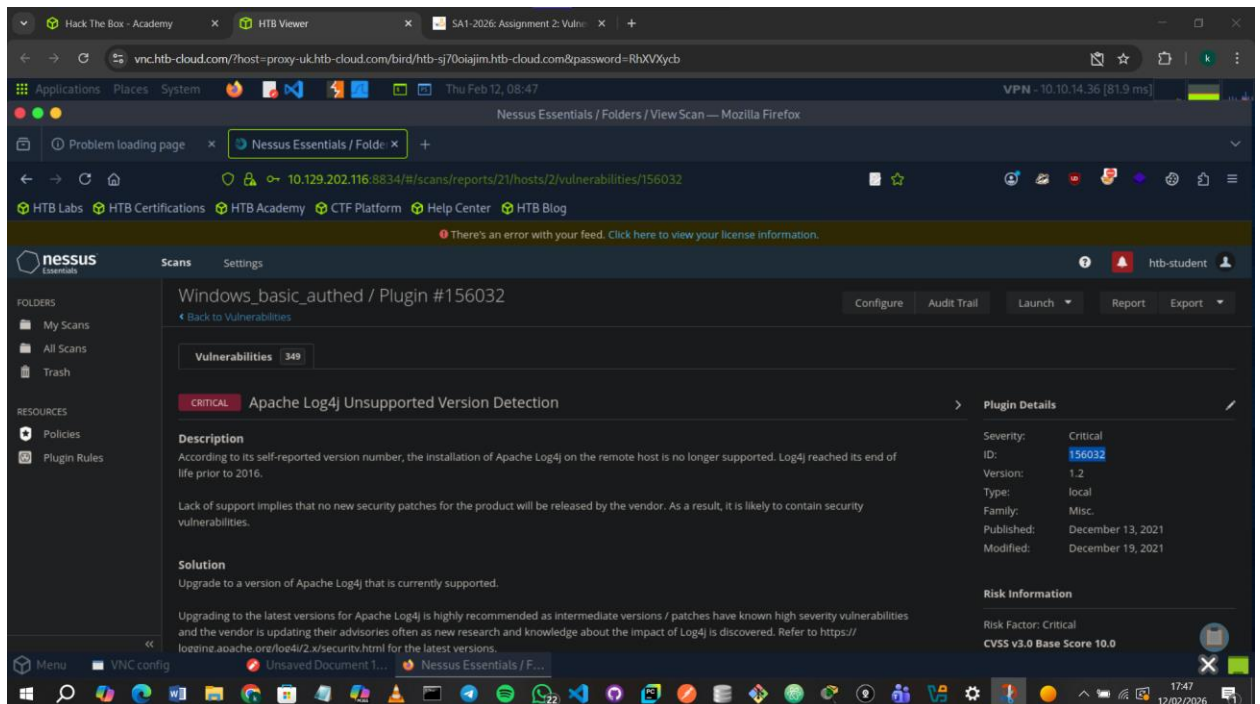


Question3: What is the plugin ID of the highest criticality vulnerability for the Windows authenticated scan?

Answer: I first located the highest critical vulnerability which I found as Apache log4j Unsupported Version Detection with a score of 10.0 and opened it.

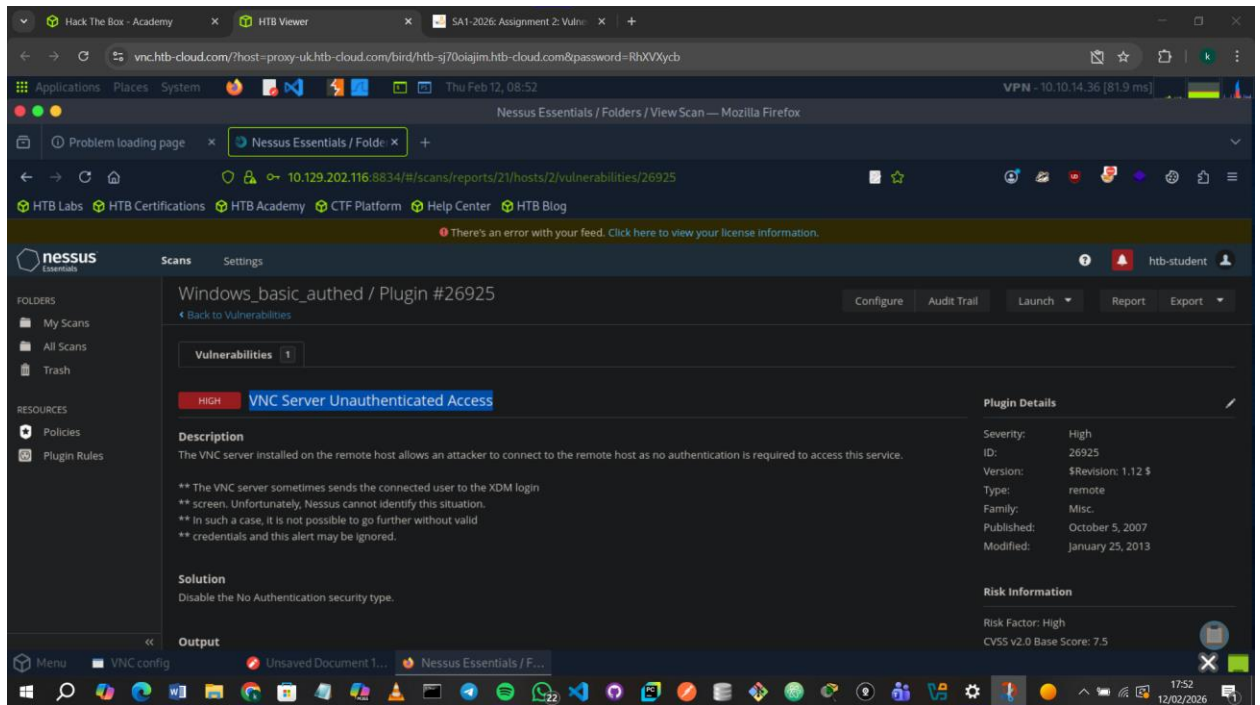


Its ID was 156032



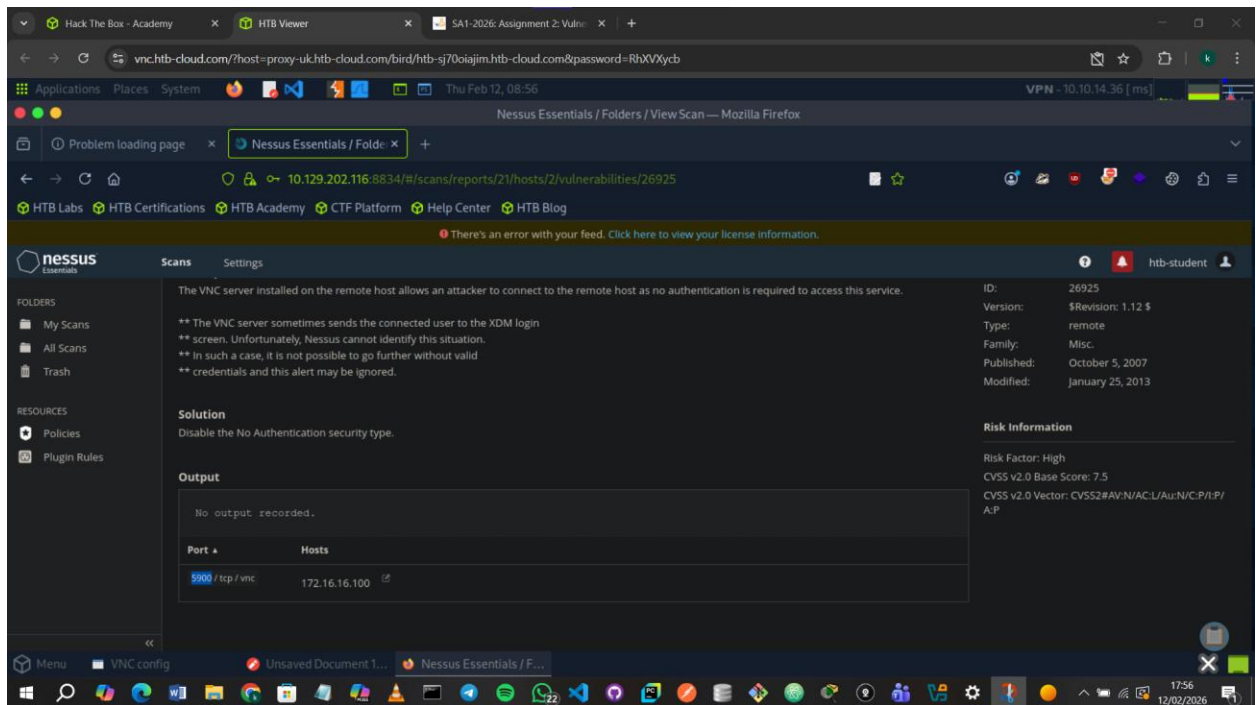
Question4: What is the name of the vulnerability with plugin ID 26925 from the Windows authenticated scan?

Answer: I filtered the results using the plugin ID 26925 and found its name as **VNC Server Unauthenticated Access**.



Question5: What port is the VNC server running on in the authenticated Windows scan?

Answer: **5900**



4.0 OpenVAS

4.1 OpenVAS Scan

I learned the difference between authenticated and unauthenticated scans, and how credentialed scans provide deeper and more accurate vulnerability results. I also understood why safer scan profiles like Full and Fast are recommended to reduce potential impact on the network.

4.2 Exporting The Results

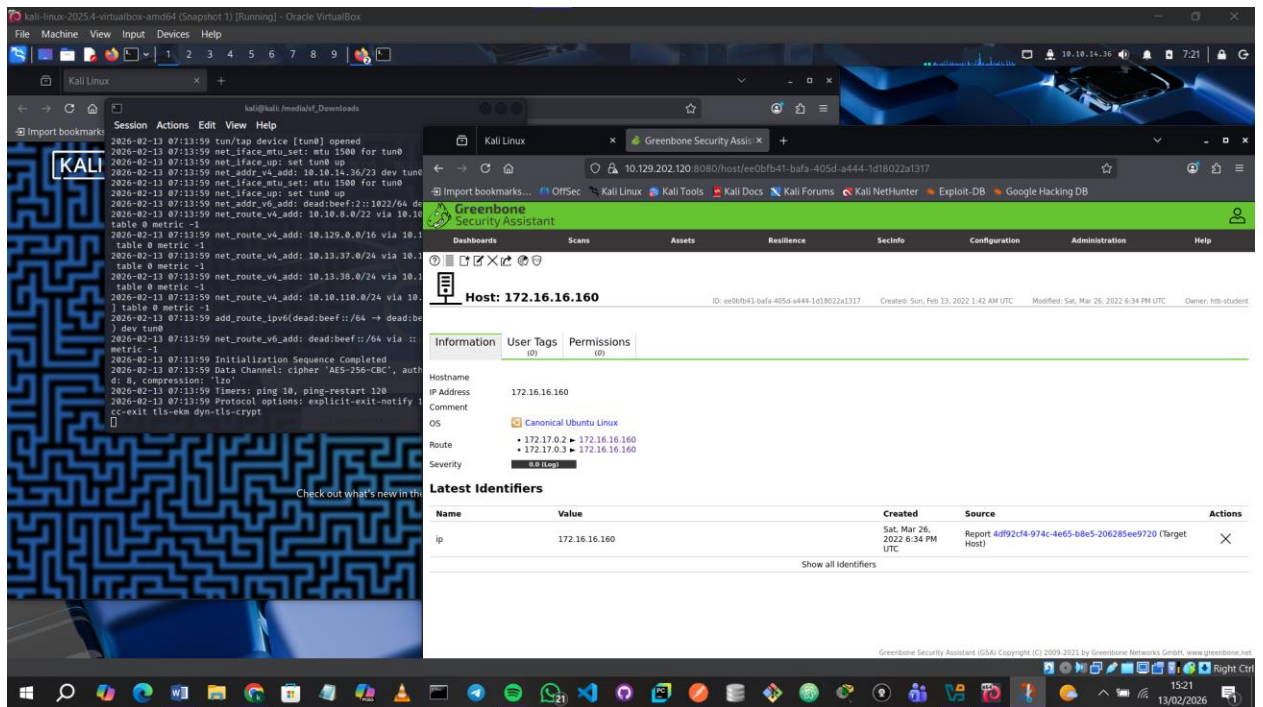
I learned how to access completed OpenVAS scan reports and review detailed findings like vulnerabilities, open ports, and services. I also learned how to export results in XML format and convert them into an Excel report using the `openvasreporting` tool for easier analysis and reporting.

4.3 OpenVAS Skills Assessment

To answer the questions I logged in to the given address at port 8080 using the provided credentials.

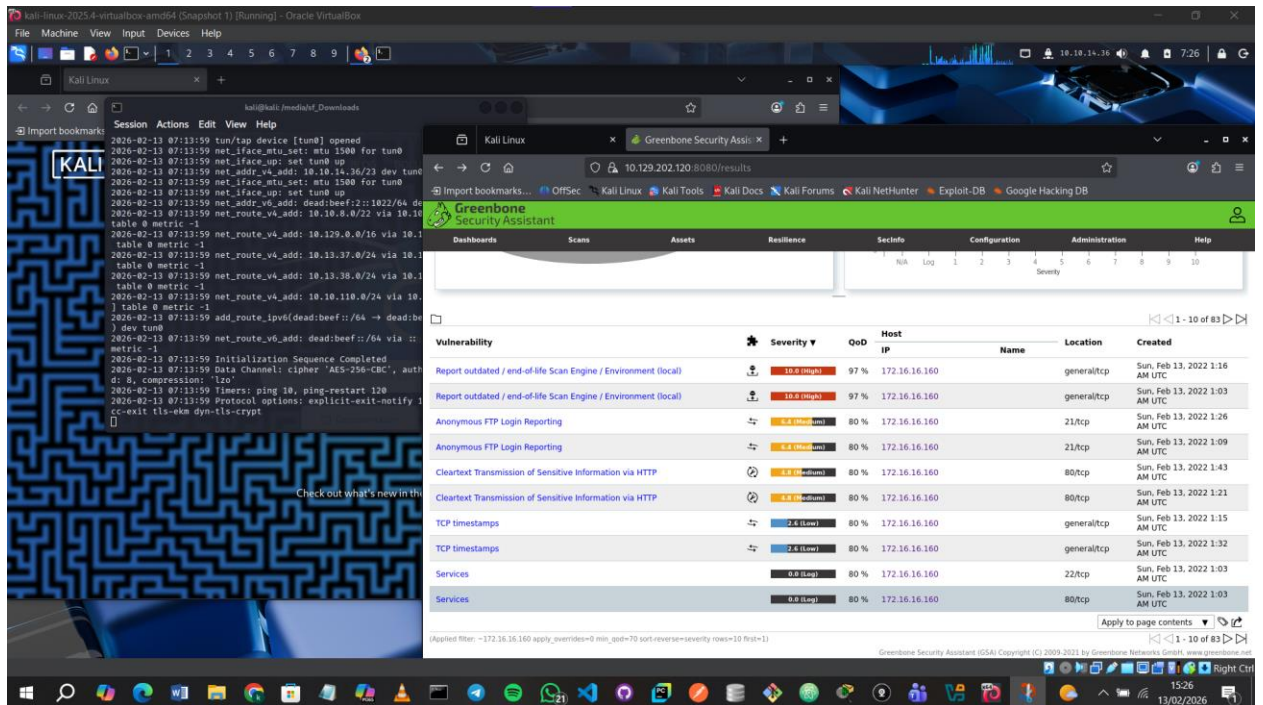
Question1: What type of operating system is the Linux host running?

Answer: I checked the scan results and filtered them and found that the OS was **Ubuntu**.



Question2: What type of FTP vulnerability is on the Linux host?

Answer: **Anonymous FTP Login Reporting**



Question3: What is the IP of the Linux host targeted for the scan?

Answer: **172.16.16.100**

Question4: What vulnerability is associated with the HTTP server?

Answer: I filtered the results using HTTP to show only HTTP ones. It was **Cleartext Transmission of Sensitive Information via HTTP**

The screenshot shows a Kali Linux virtual machine environment. On the left, a terminal window displays the following output:

```
2026-02-13 07:13:59 tun/tap device [tun0] opened
2026-02-13 07:13:59 net_iface_mtu_set: mtu 1500 for tun0
2026-02-13 07:13:59 net_iface_up: set tun0 up
2026-02-13 07:13:59 net_addr_v4_add: 10.10.14.36/23 dev tun0
2026-02-13 07:13:59 net_iface_mtu_set: mtu 1500 for tun0
2026-02-13 07:13:59 net_iface_up: set tun0 up
2026-02-13 07:13:59 net_addr_v6_add: deadbeef::2::1022/64 dev tun0
2026-02-13 07:13:59 net_route_v4_add: 10.10.8.0/22 via 10.10.14.36 metric -1
2026-02-13 07:13:59 net_route_v4_add: 10.129.0.0/16 via 10.10.14.36 metric -1
2026-02-13 07:13:59 net_route_v4_add: 10.13.37.0/24 via 10.10.14.36 metric -1
2026-02-13 07:13:59 net_route_v4_add: 10.10.110.0/24 via 10.10.14.36 metric -1
2026-02-13 07:13:59 add_route_ipv6(deadbeef::/64 -> deadbeef:: dev tun0)
2026-02-13 07:13:59 net_route_v6_add: deadbeef::/64 via :: metric -1
2026-02-13 07:13:59 Initialization Sequence Completed
2026-02-13 07:13:59 Data Channel: cipher 'AES-256-CBC', auth: 'HMAC-SHA256', compression: 'lz4'
2026-02-13 07:13:59 Timers: ping 10, ping-restart 120
2026-02-13 07:13:59 Protocol options: explicit-exit-notify 1, cc-exit tls-ekm dyn-tls-crypt
```

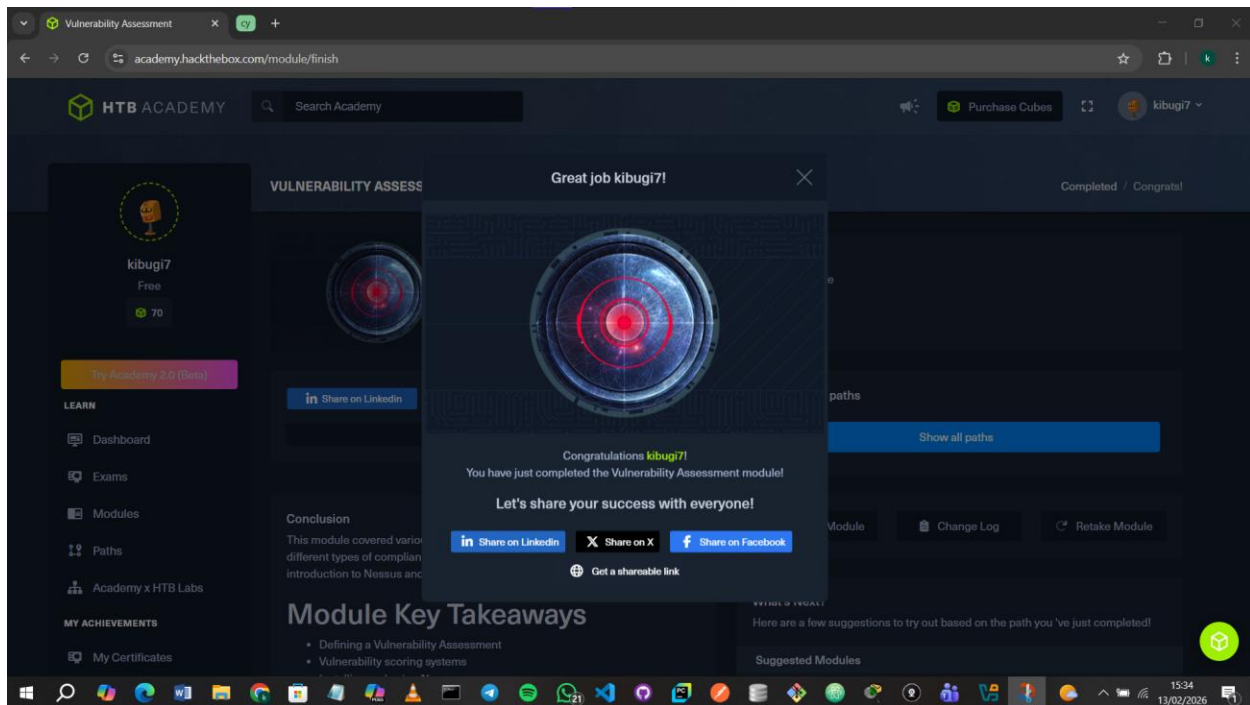
On the right, the Greenbone Security Assistant (GSA) interface is shown. The 'Vulnerability' table lists the following entries:

Vulnerability	Severity	QoD	Host IP	Name	Location	Created
Jenkins CI Groovy Console accessible	10.0 (critical)	95 %	172.16.16.100		8080/tcp	Sun, Feb 13, 2022 1:59 AM UTC
Report outdated / end-of-life Scan Engine / Environment (local)	10.0 (critical)	97 %	172.16.16.100		general/tcp	Sun, Feb 13, 2022 1:17 AM UTC
Report outdated / end-of-life Scan Engine / Environment (local)	10.0 (critical)	97 %	172.16.16.100		general/tcp	Sun, Feb 13, 2022 1:17 AM UTC
Jenkins CI Groovy Console accessible	10.0 (critical)	95 %	172.16.16.100		8080/tcp	Sun, Feb 13, 2022 2:30 AM UTC
Report outdated / end-of-life Scan Engine / Environment (local)	10.0 (critical)	97 %	172.16.16.160		general/tcp	Sun, Feb 13, 2022 1:03 AM UTC
Report outdated / end-of-life Scan Engine / Environment (local)	10.0 (critical)	97 %	172.16.16.160		general/tcp	Sun, Feb 13, 2022 1:16 AM UTC
SSL/TLS: Report Vulnerable Cipher Suites for HTTPS	7.5 (high)	98 %	172.16.16.100		443/tcp	Sun, Feb 13, 2022 1:49 AM UTC
SSL/TLS: Report Vulnerable Cipher Suites for HTTPS	7.5 (high)	98 %	172.16.16.100		443/tcp	Sun, Feb 13, 2022 2:25 AM UTC
Cleartext Transmission of Sensitive Information via HTTP	8.0 (high)	80 %	172.16.16.160		80/tcp	Sun, Feb 13, 2022 1:43 AM UTC
Cleartext Transmission of Sensitive Information via HTTP	8.0 (high)	80 %	172.16.16.160		80/tcp	Sun, Feb 13, 2022 1:21 AM UTC

5.0 Reporting

5.1 Reporting

I learned that reports must be clear and concise for all readers. Key parts: Executive Summary, Overview, Scope, and Vulnerabilities with remediation. Clear explanations make findings actionable.



Conclusion

Overall, I learned that vulnerability assessment is not just about running scans but about making informed decisions based on the results. Effective assessments require understanding compliance standards, tuning scans to avoid false positives and network disruption, and validating findings before reporting them. Most importantly, I learned that clear, concise reporting is essential to ensure stakeholders can understand vulnerabilities, prioritize remediation, and improve an organization's overall security posture.